

Encuesta Integral sobre Indicadores y Métricas de Ciberseguridad en el Marco COSO

Kit de Diagnóstico Organizacional · Versión 2025-2026

Aplicación a Organizaciones con Operaciones en España · Contexto ENS / NIS2 / DORA

"Quien no mide, no mejora. Quien no mejora, simplemente espera su turno en las estadísticas de INCIBE."
— Aforismo del practicante de GRC contemporáneo

Instrucciones Generales

Esta encuesta forma parte de un estudio de diagnóstico sobre el estado de adopción de los indicadores y métricas de ciberseguridad en el marco del Committee of Sponsoring Organizations (COSO), con aplicación territorial en España y perspectiva comparada internacional.

Tiempo estimado: 45–60 minutos · **Confidencialidad:** total, datos agregados y anonimizados.

Escala de madurez (1–5):

Nivel	Etiqueta	Significado operacional
1	Inexistente	Sin proceso formal; ausencia total o desconocimiento
2	Inicial / Ad hoc	Prácticas reactivas, sin formalizar, dependientes de personas clave
3	Definido	Documentado, estandarizado, aunque no siempre aplicado de forma consistente
4	Gestionado	Aplicado consistentemente, con métricas activas y reporte estructurado
5	Optimizado	Mejora continua, integración estratégica, benchmarking y anticipación

Las preguntas marcadas con ⚡ son **Indicadores de Alerta Temprana (IAT)**: una puntuación de nivel 1 o 2 activa revisión prioritaria.

BLOQUE 0 · Perfil del Encuestado y Contexto Organizacional

Esta sección no evalúa: simplemente nos ayuda a entender desde qué trinchera —o despacho acristalado— se responde.

P-0.1 • Rol y función en la organización (selección única)

- ☐ A. Director/a de Seguridad de la Información (CISO) o equivalente
- ☐ B. Director/a de Tecnología (CTO) / Director/a de Sistemas (CIO)
- ☐ C. Director/a de Riesgos (CRO) / Gestión de Riesgos
- ☐ D. Director/a de Cumplimiento (CCO) / Compliance
- ☐ E. Director/a de Auditoría Interna
- ☐ F. Miembro del Consejo de Administración / Comité de Supervisión
- ☐ G. Director/a General (CEO) / Alta Dirección
- ☐ H. Director/a de Operaciones (COO)
- ☐ I. Responsable de Continuidad de Negocio / Resiliencia
- ☐ J. Responsable técnico de ciberseguridad (arquitecto, analista SOC, pentester)
- ☐ K. Consultor/a externo/a o asesor/a con acceso a datos organizacionales
- ☐ L. Otro: ____

P-0.2 • Sector de actividad (selección única)

- ☐ A. Sector financiero (banca, seguros, mercados de capitales, fintech)
- ☐ B. Energía, utilities y suministros críticos
- ☐ C. Transporte y logística (aéreo, ferroviario, marítimo, por carretera)
- ☐ D. Sanidad y ciencias de la vida (hospitales, farmacéutica, dispositivos médicos)
- ☐ E. Administración pública (estatal, autonómica, local)
- ☐ F. Telecomunicaciones e infraestructura digital
- ☐ G. Industria manufacturera y sector químico
- ☐ H. Alimentación y agua (cadena agroalimentaria, tratamiento de aguas)
- ☐ I. Defensa y seguridad nacional
- ☐ J. Servicios profesionales (consultoría, auditoría, despachos legales)
- ☐ K. Educación e investigación (universidades, centros I+D)
- ☐ L. Retail, comercio y servicios al consumidor
- ☐ M. Tecnología y software (proveedores TIC, cloud, SaaS)
- ☐ N. Otro: ____

P-0.3 • Tamaño de la organización (selección única)

- ☐ A. Menos de 50 empleados (microempresa)
- ☐ B. 50–249 empleados (pequeña empresa)
- ☐ C. 250–999 empleados (mediana empresa)
- ☐ D. 1.000–4.999 empleados (empresa grande)
- ☐ E. 5.000–24.999 empleados (gran corporación)
- ☐ F. 25.000 o más empleados (corporación multinacional)

P-0.4 • Ámbito geográfico de operaciones (selección múltiple)

- ☐ A. Operaciones exclusivamente en España
- ☐ B. España y otros países de la Unión Europea
- ☐ C. España y LATAM
- ☐ D. Presencia global (más de 3 continentes)
- ☐ E. Sede internacional con filial en España

P-0.5 • Clasificación regulatoria NIS2 / ENS / DORA (selección múltiple)

- ☐ A. Entidad esencial según la Directiva NIS2 (sectores de alta criticidad)
- ☐ B. Entidad importante según la Directiva NIS2
- ☐ C. Sujeto al ENS — categoría Alta
- ☐ D. Sujeto al ENS — categoría Media
- ☐ E. Sujeto al ENS — categoría Básica
- ☐ F. Entidad sujeta a DORA (sector financiero UE, desde enero 2025)
- ☐ G. Infraestructura Crítica designada por CNI / CNPIC
- ☐ H. Ninguna de las anteriores / no aplica
- ☐ I. En proceso de determinación

P-0.6 • Presupuesto de ciberseguridad como % del presupuesto TI (selección única)

- ☐ A. Menos del 5% — la ciberseguridad parece tener dieta muy restrictiva
- ☐ B. 5–9% — en el rango europeo (mediana ENISA 2025: ~9%)
- ☐ C. 10–14% — por encima de la media, con buenas perspectivas
- ☐ D. 15–20% — organización que claramente lo ha vivido
- ☐ E. Más del 20% — o tienen mucho que proteger, o han tenido un susto memorable
- ☐ F. No existe presupuesto diferenciado para ciberseguridad
- ☐ G. Desconozco el porcentaje

P-0.7 • Tendencia presupuestaria prevista (próximos 12 meses) (selección única)

- ☐ A. Incremento superior al 20%
- ☐ B. Incremento 10–20%
- ☐ C. Incremento 1–9%
- ☐ D. Estable
- ☐ E. Reducción de hasta el 10%
- ☐ F. Reducción superior al 10%
- ☐ G. Desconocido / en negociación

BLOQUE I • Gobernanza y Cultura de Ciberseguridad

COSO ERM Componente I (Principios 1–5) • COSO CGF 2026 Principio 8

El "tono desde la cúspide" no es una metáfora zen: es la diferencia entre que el consejo pregunte "¿estamos seguros?" con datos correctos, o que lo haga mirando el techo.

P-1.1 ⚡ • Supervisión del ciberriesgo por el Consejo de Administración (selección única)

¿Con qué frecuencia el Consejo de Administración revisa el perfil de ciberriesgo?

- ☐ A. En cada sesión (mensual o mayor frecuencia) — el 41% de consejos maduros lo hacen (Deloitte 2025)
- ☐ B. Trimestralmente, como punto fijo del orden del día
- ☐ C. Semestralmente
- ☐ D. Anualmente, en el marco de la revisión general de riesgos
- ☐ E. Solo ante incidentes significativos o requerimientos regulatorios
- ☐ F. El Consejo no revisa específicamente el ciberriesgo — el mapa de amenazas lo desconoce
- ☐ G. No existe Consejo de Administración formal

P-1.2 ⚡ • Competencia ciber del Consejo (selección única)

¿Cuántos miembros del Consejo tienen formación o experiencia acreditada en ciberseguridad o riesgos digitales?

- ☐ A. Ninguno — y no parece prioridad inmediata
- ☐ B. Uno (el "tecnólogo del consejo", a quien todos miran cuando aparece la palabra "hack")
- ☐ C. Dos o tres miembros con formación relevante
- ☐ D. Más de tres miembros
- ☐ E. El 50% o más del consejo con formación formal
- ☐ F. No aplicable (PYME sin este órgano)

P-1.3 • Comité especializado de ciberseguridad en el Consejo (selección única)

- ☐ A. Sí, Comité de Tecnología y Ciberseguridad específico, activo, con reportes regulares
- ☐ B. Sí, la ciberseguridad está incluida en el Comité de Auditoría y Riesgos
- ☐ C. En proceso de creación o reestructuración
- ☐ D. No existe; el consejo pleno asume esta función cuando lo considera necesario
- ☐ E. No existe y no está previsto crearlo

P-1.4 ⚡ • Línea de reporte del CISO (selección única)

- ☐ A. Al CEO directamente — señal inequívoca de que la ciberseguridad se toma en serio
- ☐ B. Al Consejo o al Comité de Riesgos del Consejo
- ☐ C. Al CIO / Director de Tecnología, con acceso directo al consejo en asuntos críticos
- ☐ D. Al CIO / Director de Tecnología, sin línea directa al consejo — el conflicto estructural clásico
- ☐ E. Al COO / Director de Operaciones
- ☐ F. Al CFO / Director Financiero
- ☐ G. Al CRO / Director de Riesgos
- ☐ H. No existe CISO formal; funciones distribuidas o externalizadas
- ☐ I. Otro: ____

P-1.5 • Declaración formal de apetito de ciberriesgo (selección única)

- [] A. Sí, cuantificada en términos financieros (ALE, pérdida máxima aceptable por incidente)
- [] B. Sí, declaración cualitativa ("alto/medio/bajo") integrada en la política general de riesgos
- [] C. Existe borrador en elaboración, pendiente de aprobación
- [] D. No existe declaración formal, aunque hay umbrales implícitos en la práctica
- [] E. No existe y no se contempla — el apetito de riesgo es, de facto, omnívoro

P-1.6 ⚡ • Cultura organizacional de ciberseguridad (escala 1-5 por dimensión)

Dimensión	1	2	3	4	5
La alta dirección "predica con el ejemplo" en comportamiento digital seguro	☐	☐	☐	☐	☐
Los empleados reportan voluntariamente incidentes y sospechas	☐	☐	☐	☐	☐
La formación en ciberseguridad es continua y adaptada, no un trámite anual	☐	☐	☐	☐	☐
La seguridad no se percibe como obstáculo, sino como habilitador del negocio	☐	☐	☐	☐	☐
Los incidentes internos se comunican sin temor a represalias	☐	☐	☐	☐	☐

P-1.7 • Formación y concienciación (selección única)

¿Qué porcentaje de empleados completó formación en ciberseguridad en los últimos 12 meses?

- ☐ A. Menos del 20% — el phishing interno tiene muchas posibilidades de éxito
- ☐ B. 20–49%
- ☐ C. 50–79%
- ☐ D. 80–99%
- ☐ E. 100% (o prácticamente, con muy pocas excepciones documentadas)
- ☐ F. No existe programa formal de formación en ciberseguridad

P-1.8 • Gestión del talento ciber (valoración por dimensión)

Dimensión	Sin dificultad	Leve	Moderada	Alta	No hemos contratado recientemente
Atracción de nuevos profesionales ciber	☐	☐	☐	☐	☐
Retención del equipo ciber existente	☐	☐	☐	☐	☐
Cobertura de roles especializados (SOC, arquitectura, PQC)	☐	☐	☐	☐	☐

Contexto: el 76% de organizaciones europeas reporta dificultades para atraer y el 71% para retener talento ciber (ENISA NIS Investments 2025). Déficit UE: 299.000 profesionales.

BLOQUE II • Estrategia y Apetito de Riesgo Ciber

COSO ERM Componente II (Principios 6–9)

Si la estrategia de su organización no menciona el ciberriesgo, hay un tramo del mapa en blanco con la leyenda "aquí hay dragones" —y los dragones no esperan a que el plan estratégico los incluya.

P-2.1 ⚡ • Integración del ciberriesgo en la estrategia empresarial (escala 1-5)

- ☐ 1 — El ciberriesgo y la estrategia viven en universos paralelos que no se comunican
- ☐ 2 — Se menciona el ciberriesgo en la estrategia, sin compromisos ni métricas concretas
- ☐ 3 — Existe un capítulo de riesgos en el plan estratégico que incluye los riesgos ciber
- ☐ 4 — El ciberriesgo informa activamente decisiones estratégicas (M&A, inversiones digitales, nuevos mercados)
- ☐ 5 — El ciberriesgo es factor determinante en la creación de valor, cuantificado financieramente en el plan estratégico

P-2.2 • Metodologías de cuantificación financiera del ciberriesgo (selección múltiple)

- ☐ A. FAIR (Factor Analysis of Information Risk) — recomendado explícitamente por COSO y NIST
- ☐ B. VaR (Value at Risk) adaptado al ciberriesgo
- ☐ C. Simulaciones Monte Carlo para escenarios de pérdida
- ☐ D. Modelos actuariales de pérdida esperada (ALE / SLE / ARO)
- ☐ E. Modelos propietarios de cuantificación financiera
- ☐ F. Soluciones comerciales de CRQ: RiskLens, Safe Security, Bitsight, Axio, etc.
- ☐ G. Métricas cualitativas exclusivamente (matrices rojo/naranja/verde)
- ☐ H. No se realiza cuantificación financiera del ciberriesgo — las decisiones se toman a ojo
- ☐ I. En proceso de implantación

P-2.3 ⚡ • Expresión del apetito de ciberriesgo (selección múltiple)

- ☐ A. Pérdida financiera máxima aceptable por incidente individual (p. ej.: "no más de X M€")
- ☐ B. Tolerancia anual agregada como % de ingresos o EBITDA
- ☐ C. Tiempo máximo tolerable de interrupción de sistemas críticos (RTO)
- ☐ D. Máxima pérdida de datos aceptable (RPO)
- ☐ E. Nivel máximo de riesgo residual aceptable (escala numérica o financiera)
- ☐ F. Límites de riesgo regulatorio (máximo de no conformidades aceptables)
- ☐ G. Umbrales de riesgo reputacional
- ☐ H. El apetito de riesgo no está formalmente definido — es omnívoro
- ☐ I. Existe apetito ERM general que incluye implícitamente el ciberriesgo

P-2.4 • Evaluación ciber previa a iniciativas estratégicas (selección única)

- ☐ A. Sí, de forma sistemática para toda iniciativa de transformación digital, M&A, cloud o tecnologías emergentes
- ☐ B. Sí, pero solo para iniciativas de mayor impacto o inversión
- ☐ C. A veces, dependiendo del proyecto
- ☐ D. Rara vez o nunca — la evaluación ciber llega cuando el proyecto ya está en marcha
- ☐ E. No existe proceso formal de evaluación ciber en iniciativas estratégicas

P-2.5 • Inteligencia de amenazas (Threat Intelligence) (selección múltiple)

- ☐ A. Fuentes CTI comerciales (Recorded Future, Mandiant, CrowdStrike Intelligence, etc.)
- ☐ B. Integración con CCN-CERT (SEIEM, GLORIA) — sector público español
- ☐ C. Participación en ISAC/ISAO sectoriales (FS-ISAC, E-ISAC, H-ISAC, etc.)
- ☐ D. INCIBE-CERT para el sector privado español
- ☐ E. Compartición de inteligencia con pares del sector
- ☐ F. Fuentes OSINT y feeds CTI libres (MISP, AlienVault OTX, CISA KEV)
- ☐ G. Servicio de TI gestionado por MSSP externo
- ☐ H. No existe función formal de inteligencia de amenazas — las sorpresas son nuestra especialidad
- ☐ I. TI limitada a alertas del fabricante del EDR / antivirus

P-2.6 • Seguro de ciberriesgo (selección única)

- ☐ A. Sí, cobertura completa (datos, interrupción, responsabilidad ante terceros, costes de respuesta, litigios regulatorios)
- ☐ B. Sí, cobertura parcial (especifique): ____
- ☐ C. En proceso de contratación o renovación
- ☐ D. No, pero está en la agenda del año en curso
- ☐ E. No, y sin planes a corto plazo
- ☐ F. No sé si existe o qué cubre la póliza actual

BLOQUE III • Desempeño — Métricas Operativas de Ciberseguridad

COSO ERM Componente III (Principios 10–14)

El corazón latiente del sistema. Donde el mapa de riesgos deja de ser decoración mural y empieza a tener consecuencias.

P-3.1 ⚡ • Registro y gestión del inventario de riesgos ciber (selección múltiple)

- ☐ A. Registro actualizado en tiempo real, integrado en plataforma GRC
- ☐ B. Registro actualizado trimestralmente o con mayor frecuencia
- ☐ C. Registro actualizado anualmente
- ☐ D. Registro ad hoc (se actualiza ante incidentes o auditorías)
- ☐ E. Inventario de activos críticos con evaluación de riesgo asociada
- ☐ F. No existe registro formal — los riesgos son libres como pájaros
- ☐ G. El registro ciber forma parte del ERM general, sin distinción específica

P-3.2 ⚡ • Madurez en gestión de vulnerabilidades (escala 1-5 por capacidad)

Capacidad	1	2	3	4	5
Escaneo continuo de vulnerabilidades en todos los sistemas en alcance	☐	☐	☐	☐	☐
Priorización por criticidad (CVSS + contexto de negocio)	☐	☐	☐	☐	☐
Integración del EPSS (Exploit Prediction Scoring System)	☐	☐	☐	☐	☐
Proceso documentado y medido de ciclo de vida de parches	☐	☐	☐	☐	☐
Gestión diferenciada en entornos OT / IoT / ICS	☐	☐	☐	☐	☐
Seguimiento de vulnerabilidades en cadena de suministro (SBOM)	☐	☐	☐	☐	☐

P-3.3 ⚡ • Time-to-Patch de vulnerabilidades críticas (CVSS ≥ 9.0) (selección única)

- ☐ A. < 24 horas (respuesta de emergencia para zero-days explotados activamente)
- ☐ B. 1-7 días
- ☐ C. 8-30 días
- ☐ D. 31-90 días — con la incómoda compañía del 28% de organizaciones europeas (ENISA 2025)
- ☐ E. > 90 días — territorio de alto riesgo, con sus razones (legacy, OT, burocracia)
- ☐ F. No se mide — lo que no se mide, no se parchea (a tiempo)
- ☐ G. Variable según sistema (especifique): ____

P-3.4 ⚡ • Monitorización del Time-to-Exploit (TtE) como KRI (selección única)

- ☐ A. Sí, con alertas automáticas cuando el TtE cae por debajo de 72 horas en vulnerabilidades que afectan a nuestros sistemas
- ☐ B. Sí, monitorizamos el TtE pero sin automatización de alertas
- ☐ C. Seguimos feeds externos de explotación activa (CISA KEV, MISP) sin correlación con inventario interno
- ☐ D. No monitorizamos el TtE — vivimos en el presente y el futuro inmediato nos sorprende
- ☐ E. No conocemos este indicador

Contexto: En 2025 el TtE se redujo a 48–72 horas, y con automatización adversarial por IA, a menos de 6 horas. La ventana entre publicación del CVE y parcheo se ha vuelto crítica.

P-3.5 ⚡ • MTTD y MTTR (selección única por dimensión)

MTTD — Mean Time to Detect (desde inicio del incidente hasta detección):

- ☐ A. < 1 hora (detección prácticamente en tiempo real)
- ☐ B. 1–8 horas
- ☐ C. 8–24 horas
- ☐ D. 1–7 días
- ☐ E. > 7 días — tiempo suficiente para que el adversario haga las maletas
- ☐ F. No se mide

MTTR — Mean Time to Respond (desde detección hasta contención efectiva):

- ☐ A. < 4 horas
- ☐ B. 4–24 horas
- ☐ C. 1–7 días
- ☐ D. > 7 días
- ☐ E. No se mide

[illegible]

Gestión de identidades no humanas (APIs, service accounts, IoT tokens)	☐	☐	☐	☐	☐	☐
---	--------------------------	--------------------------	--------------------------	--------------------------	--------------------------	--------------------------

P-3.7 • Arquitectura Zero Trust (selección única)

- [] A. Zero Trust completamente implementado como filosofía arquitectural transversal
- [] B. Implementación parcial en dominios específicos (identidad, red, endpoints)
- [] C. Hoja de ruta ZT aprobada, en fase de implementación progresiva
- [] D. Zero Trust en el roadmap pero sin comenzar la implementación
- [] E. Arquitectura perimetral tradicional ("castle and moat") sin planes de migración
- [] F. No estamos familiarizados con el concepto Zero Trust

P-3.8 ⚡ • Riesgo de terceros y cadena de suministro (selección múltiple)

- [] A. Evaluación formal (cuestionarios, auditorías, certificaciones) para todos los proveedores críticos
- [] B. Plataforma TPRM automatizada (Bitsight, SecurityScorecard, ProcessUnity, etc.)
- [] C. Cláusulas contractuales de ciberseguridad y derecho de auditoría
- [] D. Proceso de gestión de SBOM para aplicaciones críticas
- [] E. Monitorización continua del riesgo de terceros (no solo evaluación puntual)
- [] F. Certificación ISO 27001 o ENS requerida a proveedores críticos
- [] G. Planes de continuidad que contemplan el fallo de proveedores críticos
- [] H. Evaluación básica (cuestionario) sin seguimiento continuo
- [] I. No existe proceso formal — la confianza es nuestro principal control

Contexto: el 37% de organizaciones europeas reporta dificultades en la gestión del riesgo de la cadena de suministro (ENISA NIS Investments 2025).

P-3.9 ⚡ • Resiliencia y continuidad de negocio (escala 1-5 por capacidad)

Capacidad	1	2	3	4	5
Plan de Continuidad de Negocio (BCP) documentado y actualizado (<12 meses)	☐	☐	☐	☐	☐
Plan de Recuperación ante Desastres (DRP) con RTO/RPO definidos y testados	☐	☐	☐	☐	☐
Plan de Respuesta a Incidentes (IRP) documentado, aprobado y ensayado	☐	☐	☐	☐	☐
Tabletop exercises con participación de alta dirección	☐	☐	☐	☐	☐
Pruebas periódicas de recuperación real (no solo documentación)	☐	☐	☐	☐	☐
Backups verificados (<30 días) para todos los sistemas críticos	☐	☐	☐	☐	☐

Seguridad de backups frente a ransomware (copias offline/inmuta bles)	☐	☐	☐	☐	☐
---	--------------------------	--------------------------	--------------------------	--------------------------	--------------------------

P-3.10 • Seguridad OT / IoT / Infraestructuras Críticas (selección múltiple — si aplica)

- ☐ A. Segregación de red completa entre IT y OT (air gap o red dedicada)
- ☐ B. Monitorización específica OT/ICS (Dragos, Claroty, Nozomi, etc.)
- ☐ C. Inventario completo y actualizado de dispositivos OT e IoT
- ☐ D. Proceso de actualización/parcheo de firmware en dispositivos IoT/OT
- ☐ E. Evaluaciones de vulnerabilidades específicas OT/ICS (NERC-CIP, IEC 62443)
- ☐ F. No tenemos entornos OT/IoT significativos — no aplica
- ☐ G. Tenemos OT/IoT pero sin controles diferenciados todavía

Contexto: el 85% de las botnets identificadas por INCIBE-CERT en España en 2025 están relacionadas con dispositivos IoT.

P-3.11 ⚡ • Vista de cartera del ciberriesgo agregado (selección única)

- ☐ A. Sí, con score financiero agregado (pérdida esperada total por ciberriesgo a nivel de cartera)
- ☐ B. Sí, con heat map visual de riesgos, sin expresión financiera
- ☐ C. Sí, integrada en el cuadro de mando del ERM general
- ☐ D. Visión parcial (solo algunos dominios o unidades de negocio)
- ☐ E. No existe visión consolidada del portafolio de ciberriesgos

BLOQUE IV • Riesgos Emergentes y Tendencias 2025-2026

COSO ERM Principio 6 (Contexto) + Principio 15 (Cambios sustanciales)

El menú de amenazas del futuro inmediato: IA adversarial, criptografía postcuántica y cadenas de suministro que ponen cara de inocentes hasta que explotan.

P-4.1 ⚡ • Riesgo de IA adversarial y ataques automatizados (selección múltiple)

- ☐ A. Los ataques asistidos por IA están en el registro formal de riesgos ciber
- ☐ B. Escenarios de ataque IA modelizados en ejercicios de red team / simulaciones
- ☐ C. Capacidades de detección específica para patrones de ataque automatizados
- ☐ D. Métricas de exposición a IA adversarial en el cuadro de mando ciber
- ☐ E. Controles de seguridad para sistemas de IA propios (AI Security)
- ☐ F. Conocemos el riesgo pero sin formalizarlo en controles o métricas aún
- ☐ G. No hemos incorporado estos riesgos — los dragones modernos también sorprenden

P-4.2 ⚡ • Preparación ante la amenaza cuántica (PQC) (selección única)

- ☐ A. Inventario criptográfico (crypto-agility assessment) que identifica activos con cifrado vulnerable (RSA, ECDSA, Diffie-Hellman)
- ☐ B. Hoja de ruta de migración a criptografía post-cuántica (NIST PQC 2024-25: ML-KEM, ML-DSA, SLH-DSA, HQC)
- ☐ C. Migración iniciada en sistemas de mayor criticidad o con datos de larga vida útil
- ☐ D. Riesgo cuántico en la agenda, sin acciones concretas aún
- ☐ E. El riesgo cuántico no está en nuestra agenda actual
- ☐ F. No estoy familiarizado/a con la amenaza cuántica sobre la criptografía

Contexto: El ataque "Store Now, Decrypt Later" afecta ya a datos con vida útil >10 años cifrados con algoritmos clásicos.

P-4.3 • Riesgo de IA en sistemas propios (selección múltiple)

- ☐ A. Política de uso responsable de IA aprobada por la dirección
- ☐ B. Evaluación de riesgos específica para sistemas IA/ML antes de despliegue
- ☐ C. Controles de seguridad para modelos de IA: prompt injection, data poisoning, model theft
- ☐ D. Inventario de sistemas de IA y modelos en uso (incluida IA generativa y LLMs)
- ☐ E. Cumplimiento con la EU AI Act (clasificación de sistemas por nivel de riesgo)
- ☐ F. Auditorías de seguridad específicas para sistemas de IA
- ☐ G. No utilizamos sistemas de IA propios de forma significativa
- ☐ H. Usamos IA pero sin controles de seguridad específicos todavía

P-4.4 • Seguridad en entornos cloud y multicloud (selección múltiple)

- ☐ A. Estrategia de seguridad cloud formalizada bajo el modelo de responsabilidad compartida
- ☐ B. CSPM (Cloud Security Posture Management) para detección continua de misconfiguraciones
- ☐ C. CIEM (Cloud Infrastructure Entitlement Management) para permisos cloud
- ☐ D. Controles de DLP en cloud
- ☐ E. Cifrado de datos en reposo y en tránsito en todos los entornos cloud
- ☐ F. Evaluaciones periódicas de seguridad cloud (auditorías, pentesting cloud)
- ☐ G. Gestión documentada de SLAs de seguridad con proveedores cloud
- ☐ H. Presencia en cloud sin estrategia de seguridad específica — la shadow IT es nuestro copiloto
- ☐ I. No operamos en cloud (infraestructura exclusivamente on-premise)

BLOQUE V • Marco Regulatorio y Cumplimiento

Donde la letra de la ley se encuentra con la práctica diaria, y algunos descubren que "cumplir en papel" y "cumplir en la realidad" son dos actividades que no siempre se solapan.

P-5.1 ⚡ • Estado de cumplimiento NIS2 (selección única)

- ☐ A. Cumplimiento completo y verificado (auditoría interna o externa realizada)
- ☐ B. Cumplimiento sustancial (>80% de los requisitos, con plan de cierre de brechas)
- ☐ C. Cumplimiento parcial (50–80%)
- ☐ D. Cumplimiento inicial (<50%)
- ☐ E. Evaluación en curso (análisis de brecha NIS2 iniciado)
- ☐ F. Evaluación pendiente de iniciar
- ☐ G. No estamos sujetos a NIS2

P-5.2 • Proceso de notificación de incidentes (selección única)

- ☐ A. Sí, documentado, probado y dentro de plazos regulatorios (NIS2: alerta 24h / preliminar 72h / final 1 mes)
- ☐ B. Sí, documentado pero no probado — el primer simulacro será el incidente real
- ☐ C. Procedimiento en elaboración
- ☐ D. No existe procedimiento formal
- ☐ E. Hemos tenido que notificar y el proceso fue improvisado / subóptimo

P-5.3 • Certificaciones de ciberseguridad vigentes (selección múltiple)

- ☐ A. ISO 27001 (certificado por tercero acreditado)
- ☐ B. ISO 27001 (autoconformidad o en proceso)
- ☐ C. ENS (sector público — certificación o conformidad declarada)
- ☐ D. SOC 2 Type II
- ☐ E. PCI DSS (sector de pago)
- ☐ F. TISAX (sector automoción)
- ☐ G. CMMC (sector defensa — ámbito OTAN)
- ☐ H. CSA STAR (cloud)
- ☐ I. ISO 22301 (continuidad de negocio)
- ☐ J. DORA (conformidad en curso / certificada)
- ☐ K. Ninguna certificación formal vigente
- ☐ L. En proceso de obtención de la primera certificación

P-5.4 • Cumplimiento como driver de inversión (selección única)

- ☐ A. Es el principal driver — invertimos principalmente para cumplir
- ☐ B. Driver importante, pero coexiste con motivaciones de reducción de riesgo real
- ☐ C. Factor menor — invertimos por reducción de riesgo; el cumplimiento viene de rebote
- ☐ D. La regulación aún no ha cambiado significativamente nuestra agenda de inversión

BLOQUE VI • Revisión, Mejora y Monitoreo del Control

COSO ERM Componente IV (Principios 15–17) • IC: Actividades de Monitoreo

El círculo virtuoso de quien aprende de sus propios errores, o —en la mejor versión— de los errores ajenos antes de tener que protagonizarlos.

P-6.1 ⚡ • Nivel de madurez general del programa de ciberseguridad (selección única)

- ☐ 1 — Inicial: Reactivo. Acciones ante incidentes. Sin documentación sistemática.
- ☐ 2 — Repetible: Prácticas informales, personas-dependientes, sin métricas consistentes.
- ☐ 3 — Definido: Políticas, procesos y procedimientos documentados. Se miden algunos indicadores.
- ☐ 4 — Gestionado: Programa integrado en el ERM. Métricas gestionadas y reportadas al consejo.
- ☐ 5 — Optimizado: Anticipación, TI avanzada, cuantificación financiera del riesgo, benchmarking externo.

P-6.2 • Benchmarking externo (selección múltiple)

- ☐ A. Participación en encuestas del sector (ENISA, ISACA, (ISC)², Gartner, Ponemon)
- ☐ B. Evaluaciones de madurez con marcos externos (CMMC, BSIMM, C2M2, NCSC CAF)
- ☐ C. Comparativas de ratings de seguridad (Bitsight, SecurityScorecard) vs. pares del sector
- ☐ D. Participación en grupos de trabajo o foros de CISOs del sector
- ☐ E. Ejercicios de red team / evaluaciones externas comparativas
- ☐ F. No realizamos benchmarking externo — preferimos la sorpresa

[illegible]

P-6.4 • Plataforma tecnológica de GRC (selección única)

- ☐ A. Plataforma GRC integrada (ServiceNow GRC, RSA Archer, MetricStream, OneTrust, etc.)
- ☐ B. Herramienta especializada de ciberriesgo (RiskLens, Safe Security, Axio, Bitsight)
- ☐ C. Herramienta propia o desarrollada a medida
- ☐ D. Gestión mediante hojas de cálculo (Excel) con nivel de sofisticación moderado
- ☐ E. Gestión mediante documentos de texto / listas de seguimiento sin soporte tecnológico
- ☐ F. No existe soporte tecnológico formal para la gestión del ciberriesgo

P-6.5 • Proceso post-incidente y lecciones aprendidas (selección múltiple)

- ☐ A. Análisis forense completo con informe de causa raíz (Root Cause Analysis)
- ☐ B. Lecciones aprendidas documentadas y compartidas con los equipos relevantes
- ☐ C. Actualización del registro de riesgos y de los controles afectados
- ☐ D. Revisión del IRP si se identificaron deficiencias
- ☐ E. Comunicación a la alta dirección / consejo con análisis de impacto
- ☐ F. Notificación a las autoridades competentes (INCIBE-CERT, CCN-CERT) según corresponda
- ☐ G. Seguimiento de acciones correctivas con responsable y fecha asignados
- ☐ H. El proceso post-incidente es informal o inexistente — la amnesia institucional es nuestra aliada

BLOQUE VII • Información, Comunicación y Reporte al Consejo

COSO ERM Componente V (Principios 18–20)

La última milla: donde la mejor arquitectura de seguridad puede fracasar si el consejo recibe un PowerPoint incomprensible, o —peor aún— no recibe nada.

P-7.1 ⚡ • Calidad del reporte de ciberriesgo al Consejo (selección única)

- ☐ A. Excelente: datos cuantitativos en lenguaje financiero, comparativa con apetito de riesgo, tendencias y recomendaciones accionables
- ☐ B. Bueno: mezcla de indicadores cualitativos y cuantitativos, comprensible para el consejo
- ☐ C. Mejorable: excesivamente técnico, demasiado largo o difícil de interpretar
- ☐ D. Insuficiente: resúmenes anecdóticos sin métricas consistentes
- ☐ E. Inexistente: no existe reporte formal al consejo — silencio institucional

P-7.2 • Indicadores incluidos en el reporte al Consejo (selección múltiple)

- ☐ A. Número y severidad de incidentes (por período y tendencia)
- ☐ B. MTTD y MTTR (tiempos de detección y respuesta)
- ☐ C. Estado de vulnerabilidades críticas (sin parchear vs. total identificadas)
- ☐ D. Score de riesgo de terceros / cadena de suministro
- ☐ E. Nivel de cumplimiento regulatorio (NIS2, ENS, DORA, ISO 27001)
- ☐ F. Exposición financiera al ciberriesgo (ALE, pérdida esperada en términos monetarios)
- ☐ G. Nivel de madurez vs. benchmarking sectorial
- ☐ H. Estado del programa de concienciación y cultura ciber
- ☐ I. Estado de resiliencia (RTO/RPO real vs. objetivo, resultados de ejercicios)
- ☐ J. Indicadores de riesgo de identidad (cuentas privilegiadas sin MFA, cuentas huérfanas)
- ☐ K. Indicadores de riesgo emergente (IA adversarial, quantum readiness)
- ☐ L. ROI de la inversión en ciberseguridad
- ☐ M. Ninguno de los anteriores — el consejo navega sin instrumentos

P-7.3 ⚡ • Protocolo de escalado ante incidentes significativos (selección única)

- ☐ A. Sí, con umbrales de escalado definidos, canales de emergencia y roles asignados; probado en simulacros
- ☐ B. Sí, documentado pero no probado — el primer simulacro será el incidente real
- ☐ C. Existe de facto pero no está formalizado
- ☐ D. No existe; se improvisa en función del incidente y del ánimo del momento
- ☐ E. No se contempla comunicar al consejo en la gestión de incidentes

P-7.4 • Comunicación externa ante incidentes (selección única)

- ☐ A. Sí, con política aprobada, portavoces designados, plantillas de comunicación y agencia de comunicación de crisis bajo contrato
- ☐ B. Sí, con política interna aprobada pero sin contratos externos de apoyo
- ☐ C. En elaboración
- ☐ D. No existe política formal — el "no comment" sigue siendo nuestra estrategia

BLOQUE VIII • ROI, Métricas de Inversión y Madurez Estratégica

El momento de la verdad para el CFO: ¿cuánto vale —en euros contantes y sonantes— el programa de ciberseguridad que acabamos de financiar?

P-8.1 ⚡ • Medición del ROI de la inversión en ciberseguridad (selección múltiple)

- ☐ A. Reducción del riesgo en términos financieros (pérdida esperada evitada mediante FAIR/ALE)
- ☐ B. Coste de control vs. pérdida esperada sin control (análisis coste-beneficio formal)
- ☐ C. ROSI (Return on Security Investment): reducción de pérdida esperada / coste del control
- ☐ D. Reducción de primas de seguro de ciberriesgo como proxy
- ☐ E. Comparativa con el coste de un incidente equivalente en el sector
- ☐ F. Indicadores sustitutivos no financieros (reducción de incidentes, mejora de MTTD/MTTR)
- ☐ G. No se mide el ROI — la fe es nuestro método de evaluación
- ☐ H. El ROI se justifica principalmente por requisitos de cumplimiento regulatorio

P-8.2 • Autoevaluación del Índice Global de Madurez (IGM) (selección única)

- ☐ 1 — Incipiente: la ciberseguridad existe como concepto, pero no como programa estructurado
- ☐ 2 — En desarrollo: componentes valiosos pero desconectados, sin integración estratégica
- ☐ 3 — Establecido: programa sólido, mayoría de controles implementados, sin optimización plena
- ☐ 4 — Avanzado: programa integrado en el ERM, con métricas gestionadas y reporte al consejo
- ☐ 5 — Líder de sector: cuantificación financiera del riesgo, TI proactiva, referente sectorial

P-8.3 • Principales barreras para la mejora (selección múltiple, máximo 3)

- ☐ A. Presupuesto insuficiente
- ☐ B. Escasez de talento especializado en ciberseguridad
- ☐ C. Falta de apoyo o comprensión de la alta dirección / consejo
- ☐ D. Complejidad y fragmentación del entorno tecnológico (legacy, cloud, OT, IoT)
- ☐ E. Dificultad para demostrar el valor de la ciberseguridad en términos de negocio
- ☐ F. Sobrecarga de cumplimiento regulatorio que consume recursos
- ☐ G. Resistencia cultural al cambio
- ☐ H. Falta de métricas y datos para tomar decisiones informadas
- ☐ I. Procesos de aprobación internos excesivamente lentos (burocracia institucional)
- ☐ J. Dependencia de proveedores / terceros que limita la capacidad de acción directa

BLOQUE IX • Perspectiva Comparada y Posicionamiento Internacional

¿Dónde se sitúa usted en el gran mapa global del ciberriesgo? Una pregunta más difícil de responder que de formular.

P-9.1 • Comparativa con la media del sector (selección única)

- ☐ A. Por encima de la media del sector en España y en la UE
- ☐ B. En línea con la media en España, por debajo de la UE
- ☐ C. En línea con la media tanto en España como en la UE
- ☐ D. Por debajo de la media del sector en España
- ☐ E. No disponemos de datos suficientes para hacer esta comparación honestamente

P-9.2 • Incidentes de ciberseguridad en los últimos 12 meses (selección única)

- ☐ A. Ninguno registrado
- ☐ B. 1–3 incidentes
- ☐ C. 4–10 incidentes
- ☐ D. Más de 10 incidentes
- ☐ E. No llevamos registro formal de incidentes — los contamos por las cicatrices

Si ha sufrido incidentes, ¿cuál fue el tipo predominante? (selección múltiple)

- ☐ A. Ransomware / cifrado de datos
- ☐ B. Phishing / ingeniería social (con éxito)
- ☐ C. Brecha de datos (exfiltración)
- ☐ D. Ataque DDoS / interrupción de servicio
- ☐ E. Compromiso de la cadena de suministro / tercero
- ☐ F. Acceso no autorizado (insider o externo)
- ☐ G. Fraude financiero / BEC (Business Email Compromise)
- ☐ H. Compromiso de sistemas OT / ICS
- ☐ I. Otro: ____

P-9.3 • Prioridades de inversión para los próximos 12 meses (selección múltiple, máximo 5)

- ☐ A. Detección y respuesta (EDR, XDR, MDR, SIEM/SOAR)
- ☐ B. Gestión de identidad y acceso (IAM, PAM, Zero Trust)
- ☐ C. Seguridad cloud y SASE
- ☐ D. Gestión de vulnerabilidades y patch management
- ☐ E. Riesgo de terceros y cadena de suministro
- ☐ F. Continuidad de negocio y resiliencia
- ☐ G. Cumplimiento regulatorio (NIS2, DORA, ENS)
- ☐ H. Concienciación y formación del factor humano
- ☐ I. Seguridad OT / IoT / sistemas industriales
- ☐ J. Criptografía post-cuántica / quantum readiness
- ☐ K. Seguridad de IA (AI Security)
- ☐ L. Cuantificación financiera del ciberriesgo (CRQ / FAIR)
- ☐ M. Inteligencia de amenazas (Threat Intelligence)
- ☐ N. Automatización y orquestación de seguridad (SOAR, SIEM)

BLOQUE X • Reflexión Final y Aportaciones Abiertas

El espacio más valioso de la encuesta: donde la realidad supera siempre al cuestionario.

P-10.1 • Valoración general del marco COSO para el ciberriesgo (escala 1-5 + comentario)

- ☐ 1 — No lo conozco en profundidad o no lo utilizamos
- ☐ 2 — Lo conozco, pero no lo aplicamos al ciberriesgo
- ☐ 3 — Lo utilizamos como referencia, aunque no de forma sistemática
- ☐ 4 — Es parte integral de nuestro enfoque de gestión del ciberriesgo
- ☐ 5 — Es el backbone de toda nuestra arquitectura de gobierno del riesgo ciber

Comentario abierto (opcional): ____

P-10.2 • La métrica que más ha transformado su gestión del ciberriesgo (respuesta abierta)

Si tuviera que nombrar UNA métrica o indicador que haya transformado genuinamente la forma en que su organización gestiona el ciberriesgo, ¿cuál sería y por qué?

(Este es el espacio donde, paradójicamente, más se aprende.)

P-10.3 • El mayor reto de ciberseguridad para su organización en 2026 (respuesta abierta)

P-10.4 • Indicadores que deberían incorporarse al marco COSO (respuesta abierta)

¿Qué indicadores o métricas, que actualmente no utiliza o no están en COSO, considera que deberían incorporarse?

Protección de Datos

Los datos se tratarán conforme al RGPD (UE 2016/679) y la LOPDGDD (LO 3/2018). Finalidad: investigación académica y diagnóstico sectorial. Sin cesión a terceros ni fines comerciales.

Responsable del tratamiento: [Institución investigadora] · Contacto DPO: [email]

Kit COSO-Ciber v2025.1 / Bases: COSO ERM 2017 · COSO IC 2013 · COSO CGF 2026 · ENISA NIS Investments 2025 · INCIBE Balance 2025 · CCN-CERT 2025 · NIST IR 8286r1 · FAIR Institute 2025 · NIS2 · DORA · ENS (RD 311/2022)